Summary

What I built:

3 node k8s cluster with 1 control plane and 2 worker nodes on verda (FIN-01, CPU.4V.16G, Ubuntu 24.04). The nodes are set up using the verda terraform provider and they are configured using a bootstrap script.

There are two tenants: **demo** and **tenant-b**.
For the rest of the repo structure I have added one liner for each dir.

Choices I made and why?:

- **RKE2 over Kubeadm:** Since it comes with CIS benchmarks, etcd encryption, audit logging and PSA out of the box, I was able to spend my time more on the bonus items, since basic is covered by default.
- **Cilium over Calcio:** since cilium offers most of the component by default in cilium-agent without switching to enterprise version unlike calcio (for L7 & FQDN policies, network observability with hubble)
- **Kyverno validating policy (CEL) over Gatekeeper:** K8s native and policy readable as yaml. No learning curve like rego.
- **Sealed secret over ESO:** Since I didn't find any secret store in Verda and ESO would require one, so kept it basic for now.
- **Ufw over Cilium host firewall:** I wanted to use a cloud native firewall solution (but since on verda it was available on beta version), so i have gone with ufw instead of cilium host firewall, as firewall should work on host level even without the cluster in place (and cilium would need one), also host firewall won't be editable by cluster admin. We can have cilium policy as well but as Defence in depth.
- **Falco over tetragon:** this I dont have specific reasoning, only that I am more familiar with falco but will try reading more about it.

All above choice are the one's that I have worked on in the past except the RKE2.

What worked:

- **Host firewall and SSH:** tried listening on every port on all nodes from internet but only control plane was allowed on port 1:22, others were blocked.
- **Admission Control (Kyverno with PSA):** tried using :latest, untrusted registry, privileged pod, unsigned images but all of them got rejected with the admission control.
- **Network (cilium):** Traffic was allowed to only api.github.com on backend and default deny policy was applied.
- **Runtime (Falco):** detection for shell in container api call from pod
- **Observability (Alerts):** important ones - shell spawned in container, critical vulnerability running, admission request denied.

- **Secrets:** no plaintext secret on git, restricted secret permission using rbac, and etcd was encrypted.
- **Supply chain and CI:** unsigned image, critical cve and malformed manifest were detected and flagged in CI workflow.
- **Benchmarking:** CIS benchmark passed for both control plane (62 passed, 4 failed, described below in gaps) and worker node.

What didn't worked:

- Bootstrap script (claude written) locked me out of cp-1. So needed to rebuild the node.
- Falco API rule was noise, since argo cd, kyverno, prometheus talks to the API all day. Excepted platform namespaces.
- Inside gVisor, host Falco was blind (shell and API call in a sandboxed pod were sending no events). So current two tiers are: Untrusted workloads are running with gVisor (isolation), and standard on runc with Falco (visibility).
- I tried running nmap on nodes to confirm the port block but it strangely reported 660 open ports that nothing listens on (maybe something upstream was answering the scans). So did a test that probes each node's real sockets from outside.

Gaps:

- On the benchmarking side, all checks pass except for the platform component which needed broad access (kyverno, argo, rke2 add ons). So per component RBAC review is required.
- Also platform component does not have default deny.
- There is no custom api audit policy, also the logs stores on control plane node. (should be outside cluster in tamper proof storage with detection on it).
- SSH on cp-1 is there for port 22. A vpn (tailscale, teleport) can be used to avoid open port 22.
- There is no mTLS between services. WireGuard encrypts traffic between nodes, but services have no identity. The better way would be Cilium mutual auth (SPIFFE) or a service mesh.
- Single control plane
- Long lived certs compared to OIDC per person.

Small note:

- For the demo log file, I have used claude to generate a scripts/demo.sh script which in turn created the docs/demo-log.md file (it looked more cleaner than me creating a log file).
- sorry for inconsistent tenant naming, gave wrong claude prompt 🥲
- Some things might repeat in different md files and docs.
- CI tests are failing again due to a new finding, CVE-2026-111497 (brotli-libs 1.2.0-r1, CRITICAL, fixed in 1.2.1-r0) in the pinned nginx-unprivileged:1.31.7-alpine. The plan is to bump the digest once nginxinc publishes a rebuild. For now, the gate is doing its job by catching a new CVE in an already-pinned image.